

**Necton Primary School, Audit Report****Audit Date: 12 March 2020****Report: Year 2 visit 3****DPE: Linda Mortimer****School member:****Business Manager - Tania Freestone**

---

**1. Visit details**

Details highlighted at the time of the last visit were discussed. GDPR documents and policies were also reviewed. This included DPE Best Practice areas, Compliance Checklists, SLA tool, Record of Processing and Compliance Manager being discussed and demonstrated to the school. The themed audit carried out by NCC in Summer Term 2019 was also talked through (refer to section 6 below) as well as when the need arises for completing a Data Protection Impact Assessment (DPIA), (refer to section 5.1 below).

**Review actions recommended at time of previous visit – 13.11.19**

**All recommendations made during previous visit have been actioned apart from below, and the following is noted:**

**Knowledge Bank:** The school has only recently been able to access Knowledge Bank successfully.

**GDPR Policy:** Has the school adopted the DPE model policy. Ensure that Data Protection Education is noted as the DPO

**Privacy Notice:** Has this been amended to show DPE as the DPO. This should include a more detailed list of third parties with whom the school shares PII data.

**GDPR Training:** Review progress made with GDPR training. At the time of the audit on 12.3.20, School Administrator added staff details to Knowledge Bank to enable training to be rolled out.

**Best Practice Checklists:** Review progress made with the completion of these checklists.

**Compliance Manager:** Has the school used this to upload key documents and share with staff ie Working Away from School.

**Policies:** Records Management, Information Classification, FOI – adopted by the school and published on website  
Clear Desk and Working away from School – adopted by school and shared with staff.

**Audit walk findings & recommendations on 12.3.20**

**GDPR Policy:** School Administrator will check that that DPE model GDPR Policy (Version 2019 v1.4) has been ratified by Governors.

**Action:** If the DPE model policy has been agreed and adopted by the Governing Body, please publish on the school website.

**Privacy Notice:** Is published on the school website.

**Action:** Remove Stuart Lee as the named DPO and replace with Data Protection Education

---

**Action:** Please add a more detailed list of third parties with whom the school shared PII data. DPE will provide an example list

**Action:** Ensure that visitors are signposted to the location of the school's Privacy Notice.

**GDPR Training:** All school staff should complete GDPR 101 training and this should be included in new staff induction. DPE recommend that this training should be refreshed every two years and there will be a 20 minute refresher course available shortly on Knowledge Bank. There are now many bite size training sessions available on Knowledge Bank.

**Action:** Prioritise SLT, Senior Admin and school Caretaker to complete GDPR 101 training and the roll out to remaining staff.

**Best Practice Checklists:** At the time of the visit, these lists were reviewed and significant progress was made with their completion.

**Action:** School to continue to keep these under review and complete as appropriate.

**Compliance Manager:** This was demonstrated to the School Administrator for the sharing of key documents with staff.

**Action:** If not already actioned, the school can share Working out of School, Clear Desk Policy, Photo and Video guidelines and the Breach Procedure via the Compliance Manager.

**Other Policies:** DPE recommend that the following policies are adopted by the school; Information Classification, Freedom of Information, Records Management, Password Policy and the SAR Procedure (share the SAR Procedure with SLT and senior admin).

**Action:** Model DPE policies and guidance were downloaded at the time of the audit and can be adapted for the school to use.

**Cashless Catering:** School are looking into introducing cashless catering via Pupil Asset. DPE suggest that a Data Protection Impact Assessment is completed prior to the introduction of cashless catering. DPE will provide a blank standard template for a DPIA.

**SEND Record Management:** All SEND paperwork is retained securely by the SENCo.

**Management of Student Assessment:** The school uses cloud based PIXL Assessment module, which means that no hard copies of assessments are generated. This limits access to personal/confidential data.

**Management of Communication with Parent:** The school uses Pupil Asset for texting and emails to parents.

**Publication Scheme:** This was discussed and examples will be provided for the school to make reference to. More guidance can be found under the News tab on the Knowledge Bank. DPE are developing a generic Publication Scheme which should be available after Easer.

**Naming convention:** All exercise books, work trays, files, displays and coat pegs use first names only.

**Laptops:** Are encrypted, password protected and accounted for on a regular basis

**Action:** School to share the Working Away from School Policy with all staff who work at home. This can be managed via Compliance Manager on Knowledge Bank - tbc.

**Server:** Is situated in a dedicated room.

**Action:** The school will check whether the IT Technician has procedures for regular cleansing of the server.

**School Kitchen:** Operated by Norse. All allergy information is kept securely.

**Staffroom:** Staff pigeonholes are no longer in place and now all staff have a locker which is secure.

**First Aid Records:** Records are stored securely.

**Medical Student Care Plans:** Are stored securely in student files kept in a locked cabinet.

**RoP Checklist:** This was reviewed with the school to identify and confirm the top 100 management processes which will be used when the RoP mapping exercise commences.

**GDPR Self-Audit:** The school will introduce a programme of self-audit and this could include the GDPR Governor.

**Confidential Data Destruction:** This is managed through Avena.

#### **Classrooms and Other Areas of the School**

All classrooms have a Red File containing SEND information, student support plans and diagnostic reports.

**Action:** Please ensure that all staff are aware of the importance that this information is stored securely at the end of the day, when the classroom is left unattended, weekends and school holidays.

**Reception Classroom:** A folder containing student pre-school information was available. Information relating to NHS referral as well as speech and language records were also easily accessible.

**Action:** Ensure that such information is kept securely at all times.

**Year 6 Classroom:** Statistical information detailing student's full names and students results from previous academic year were found in a bag underneath the teacher's desk.

**Action:** Ensure that such information is stored securely.

**Year 4 Classroom:** Various lists detailing student's full names were visible. These included After School Clubs, Fun Fitness Club, Multi-Sport Club, Merit List, Times Tables and Spellings List.

A walking home list was also available, detailing student's full name and parent contact details.

A list of student's computer log-ins and passwords was accessible on the teacher's desk.

A file containing student's communication records was easily accessible.

A computer and laptop were found to be unlocked and the laptop enabled access to the full network.

**Action:** Please remind all staff of the importance of using first name only on lists which are on general display.

Re-iterate the importance of keeping the above information securely as well as locking computers when left unattended.

## **2. Compliance actions that should now be completed**

### **Initial documents:**

- **Privacy Notice**
- **GDPR Policy**
- **Data Breach Procedure**

- SAR procedure
- Photo and Video consent, guidelines and records

Ideally you would also have: Work away from school, clear desk and screen, information classification and record management policy/paperwork. Schools have either adopted the DPE models or incorporated some of this within their staff handbook, for example, work away from school.

#### The following should also be completed:

- There should be no named person on any of the above documents. If there is a named person i.e. Stuart Lee, the name needs replacing with: Data Protection Education Ltd;
- The Privacy Notice should have an appendix with your third-party suppliers listed. You should also make sure suppliers are GDPR compliant;
- The Privacy Notice, GDPR Policy and consent withdrawal form should be displayed on the school website;
- All staff should know what the data procedure is, and the document should be circulated to all staff;
- Key staff responding to SARs should have access to the SAR procedure and understand their responsibilities.

## 2.1. Data retention schedule:

By now you should be working through both physical and electronic data and have a good understanding of what data you hold and be documenting this. There are a number of documents available to support the process:

- Governor hub: annual review of school data and safe data destruction checklist
- IRMS toolkit: [https://c.ymcdn.com/sites/irms.site-ym.com/resource/collection/8BCEF755-0353-4F66-9877-CCDA4BFEEAC4/2016 IRMS Toolkit for Schools v5 Master.pdf](https://c.ymcdn.com/sites/irms.site-ym.com/resource/collection/8BCEF755-0353-4F66-9877-CCDA4BFEEAC4/2016%20IRMS%20Toolkit%20for%20Schools%20v5%20Master.pdf)
- DfE toolkit  
[https://assets.publishing.service.gov.uk/government/uploads/system/uploads/attachment\\_data/file/747620/Data Protection Toolkit for Schools OpenBeta.pdf](https://assets.publishing.service.gov.uk/government/uploads/system/uploads/attachment_data/file/747620/Data_Protection_Toolkit_for_Schools_OpenBeta.pdf) (Annex 5,1)

## 2.2. Staff training

GDPR training has been completed and documented for the majority of staff. If not already you should:

- Rollout training to key staff and then consider all staff completing the e-learning training;
- Add as part of the induction process for new staff;
- Use staff meetings/briefings to raise staff awareness.

## 2.3. Governance check

It should form part of governance that GDPR is an item at governor meetings and to share reports with governors. Ideally the governor responsible for GDPR will have completed some form of GDPR training.

## 2.4. Make sure DPE is your registered DPO with the ICO

Not only do you need to be registered as a controller with the ICO, it is a requirement to register who your DPO is. The guide to complete this is available from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news/83-best-practice-updates/110-make-sure-dpe-is-your-registered-dpo-with-the-ico>

# 3. Freedom of Information and Publication Scheme

The DPE GDPR policy and FOI policy content refer to the organisation having a publication scheme - do you have one? **The template for a model publication scheme can be obtained from:** <https://ico.org.uk/media/for-organisations/documents/1235/definition-document-schools-in-england.pdf> How to complete a publication scheme guide can be obtained from: <https://ico.org.uk/media/for-organisations/documents/1242/how-to-complete-template->

---

[guide-to-info-for-schools.pdf](#) Additional guidance can be obtained from the news section of the DPE website: <https://kb.dataprotection.education/news-top/news>

## 4. Technical measures

DPE recommends schools complete the Cyber essentials questionnaire available from: DPE>Resources> Information Technology Security: <https://kb.dataprotection.education/best-practice-library/documents/information-technology-security/7-crest-cyber-essentials-questionnaire>;

Check iPad/Tablet security. Are all laptops encrypted, does your end of day routines include housekeeping to remove data no longer needed and is equipment secured? Do staff still use unencrypted memory sticks? DPE recommends schools develop procedures to ensure iPads can be accounted for daily and data (i.e photos) can be cleared if lost or stolen ([Erase your device](#))

## 5. Next steps

### Record of Processing (RoP) tool and data mapping

DPE have started to populate the Record of Processing (RoP) tool. Rather than each school complete individually, DPE will be populating as many processes as possible and then work with you to complete for your school. It is a requirement under article 30 of the GDPR and will form part of the basis for future remote sessions and visits.

### 5.1. Data Protection Impact Assessments (DPIA)

When processing high risk personal data and using new technologies (i.e. moving to a new technology for Safeguarding) a DPIA should be completed and the DPO consulted (Article 35.2). DPIAs offer a risk assessment template where concerns can be noted alongside mitigating actions to reduce the overall risks related to change of practice. It is good practice to complete a DPIA for any major project where the processing of personal data is required. DPE will be providing more guidance, training and include risk management within the RoP tool. Always contact DPE in the first instance.

## 6. Norfolk County Council Summer GDPR audits

NCC auditors completed several themed GDPR audits during the summer term 2019. DPE have provided feedback to the findings which can be obtained from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news>